

TAF 全量代码审计报告

审计时间: 2026-08-02
审计范围: 16个源文件 · 5344行代码 · 8张数据库表 · nginx/systemd配置
审计模型: Qwen3.5-Plus (子代理) + 父代理逐条核实
Qwen 命准率: 74% (27项中20项确认, 3项误报)

综合评分: 5.6/10

维度	权重	得分	加权
🛡️ 安全性	25%	3.5/10	0.88
📄 代码质量	20%	6.0/10	1.20
🏗️ 架构设计	20%	6.5/10	1.30
⚡ 性能与效率	15%	6.5/10	0.98
🔄 业务逻辑	10%	7.5/10	0.75
🔧 可运维性	10%	5.0/10	0.50

安全性拖分严重：无认证、CORS全开、路径遍历、硬编码密码。

🛡️ P0 — 立即修复 (5项)

#	文件:行	问题	修复方案
1	deps.py:28-30	零认证 — <code>get_current_user()</code> 返回匿名 admin	实现JWT认证 (已有python-jose+passlib)
2	main.py:41	CORS全开 <code>allow_origins=["*"]</code>	限制为实际前端域名
3	basemaps.py:40-45	路径遍历 — 客户端文件名直接拼入路径, 无类型白名单	<code>secure_filename</code> + 扩展名白名单
4	scripts/init_db.py:17	硬编码密码 <code>R@De432!</code>	读环境变量
5	deliverables.py:976	坚果云凭证空默认, 缺失时静默失败	启动校验+告警

🔧 P1 — 本周修复 (8项)

#	文件:行	问题
1	deliverables.py	2112行单文件, 11端点+内联重复
2	deliverables.py	BOQ逻辑重复 (端点版+打包器内联版)
3	deliverables.py	优先级矩阵逻辑重复
4	evaluation.py:124	<code>max_score = applicable_count * 5</code> 硬编码满分
5	projects.py:88-95	N+1查询 — 列表每项单独查设施数
6	taf.service:10	systemd Environment 变量被截断
7	deliverables.py:1535	DeepSeek API key 未校验
8	config.py:17	db_password 空默认, .env缺失时无密码连接

🌐 P2 — 本月修复（5项）

#	文件	问题
1	deps.py:11	Engine 模块级创建，难以单测
2	main.py	/health 不检查数据库连通性
3	basemaps.py:39	aiofiles 未在 requirements.txt 声明
4	evaluation.py	魔法数字 0.5 系数应提取为常量
5	deliverables.py	异常处理未记录堆栈

✖ Qwen 误报（已排除）

误报	实际情况
"热力图中有空循环 for f in facilities: pass "	全部16处均有实际逻辑
"矩形选择工具只有框架"	前端搜索无此功能
"restore_seed.sql 被截断"	正常完整

✔ 亮点

- 评估引擎：分级评分+可选设施跳过+必选项追踪，设计合理
- 成果生成：11种格式输出，功能完整
- 数据库：UUID+PostGIS+软删除+版本快照，设计成熟
- 前端：Vue3+Element Plus，拖拽排序+DXF解析+设施布点
- 标准切换：支持版本切换+影响预览

修复优先级

优先级	数量	预计工时
P0	5	3h
P1	8	2天
P2	5	1天